

Closing the Security Activation Gap: A Security-by-Design Methodology for IoT Ecosystems and Its Empirical Validation in a DC Smart Microgrid

Raziel Campos-Sanchez^{a,b,*}, Luis Hernandez-Martinez^a, Claudia Feregrino-Uribe^{b,c}, Alejandro Penuelas-Angulo^{d,e}, Diego Cruz-Aguilar^{b,c}

^a*Electronics Department, National Institute of Astrophysics, Optics and Electronics (INAOE), Luis Enrique Erro 1, San Andrés Cholula, 72840, Puebla, Mexico*

^b*Science and Technologies of Security Department, INAOE, Luis Enrique Erro 1, San Andrés Cholula, 72840, Puebla, Mexico*

^c*Computational Sciences Department, INAOE, Luis Enrique Erro 1, San Andrés Cholula, 72840, Puebla, Mexico*

^d*CEIT-Basque Research and Technology Alliance (BRTA), Manuel Lardizabal 15, Donostia/San Sebastián, 20018, Guipuzcoa, Spain*

^e*Universidad de Navarra, Tecnum, Manuel Lardizabal 15, Donostia/San Sebastián, 20018, Guipuzcoa, Spain*

Abstract

A persistent security activation gap constrains the widespread adoption of IoT ecosystems: security mechanisms are widely available in commercial platforms yet remain inactive after standard deployment. Closing this gap requires not only improved tools but also a methodology that embeds cybersecurity as a foundational design concern from the earliest development stages. We present a security-by-design methodology for centralized IoT ecosystems that treats identity as an intrinsic entity property, spans seven stages across four phases, and integrates cybersecurity throughout the development life-cycle. A dynamic Root of Trust process establishes verifiable cryptographic identity for each entity, providing the trusted foundation for authentication, access control, and secure communication.

*Corresponding author

Email addresses: rcampos@inaoe.mx (Raziel Campos-Sanchez), luish@inaoe.mx (Luis Hernandez-Martinez), cferegrino@inaoe.mx (Claudia Feregrino-Uribe), apenuelasan@ceit.es (Alejandro Penuelas-Angulo), diego.cruz@inaoe.mx (Diego Cruz-Aguilar)

We validate the methodology through a confirmatory case study (Yin, 2014) applying all seven stages to the design and implementation of a DC Smart Microgrid (SMG): an industrial IoT ecosystem comprising two ESP32-based secondary control nodes and a Raspberry Pi 4B primary coordination agent. Four case study questions (CSQ1–CSQ4) evaluate guidance sufficiency, identity model unambiguity, Root of Trust verifiability, and threat coverage. Results show: CSQ1—all seven stages produced documented, traceable artifacts with no external guidance required; CSQ2—a 12-parameter identity model across four entity types was produced without ambiguity; CSQ3—the Root of Trust process established mutual authentication with 56.7ms total P2+P3 handshake latency (averaged across two independent bench runs), per-message P4 latency of 30.3 ± 3.3 ms (196 pooled bench messages, NODE_02), and 100% chain integrity with zero security errors; CSQ4—unweighted OWASP IoT Top 10 coverage of 8/10 items fully addressed and 2/10 partially addressed (I4 secure-update policy only; I10 physical hardening outside software scope). The methodology’s parameterized, technology-agnostic structure is designed to generalize across diverse IoT application domains; empirical validation in additional domains remains future work.

Keywords: Internet of Things, Security-by-Design, IoT Methodology, Root of Trust, Identity Management, Smart Microgrid, Case Study Research

1. Introduction

The Internet of Things (IoT) has evolved from a conceptual vision into a technological paradigm underpinning critical infrastructure, industrial automation, healthcare systems, and smart cities (Al-Fuqaha et al., 2015; Zhou et al., 2021). Despite this expansion, large-scale IoT adoption remains constrained by fragmented architectures, heterogeneous technologies, and—critically—the failure to integrate cybersecurity from the earliest design stages (Shahinzadeh et al., 2024; Makhdoom et al., 2018).

The consequences of this gap are well documented. The Mirai botnet, which compromised over 600,000 IoT devices to launch unprecedented distributed denial-of-service attacks, originated from misconfigured or unprotected deployments relying on default credentials (Antonakakis et al., 2017). Subsequent analyses confirm that cyberattacks on IoT infrastructure continue to escalate in frequency and sophistication, targeting energy systems,

healthcare networks, and public utilities (Abraham et al., 2025; Okika et al., 2025).

A central observation motivating this work is that the principal barrier to secure IoT deployment is not the *absence* of security features but the *security activation gap*: the disconnect between security capabilities *available* in a platform and those *operational* after a standard deployment (Figure 1). Widely adopted open-source IoT platforms provide security mechanisms that require manual post-installation configuration, effectively restricting their use to organizations with dedicated security expertise (Fagan et al., 2021).

A second, more fundamental barrier operates at the methodological level: most IoT development projects lack a structured process that integrates cybersecurity from organizational decision-making through operational maintenance. Security is typically addressed *after* architectural and technology decisions are made, producing mechanisms that are bolt-on rather than foundational, with identity management that is platform-specific rather than entity-centric.

To address both barriers, we present two complementary contributions:

1. **A security-by-design methodology** for developing centralized IoT ecosystems. The methodology treats identity as an intrinsic property of every entity, spans seven stages across four phases (organizational strategy, architecture, implementation, and operation), and embeds cybersecurity—from threat policy to Root of Trust establishment—as a foundational concern from problem definition through ongoing operation. A dynamic Root of Trust (RoT) process establishes verifiable cryptographic identity for each entity before any operational communication begins.
2. **An empirical confirmatory case study** applying the methodology to the design and implementation of a DC Smart Microgrid (SMG) IoT ecosystem, following Yin’s (2014) Case Study Research design. The SMG comprises two ESP32 secondary control nodes and a Raspberry Pi 4B primary coordination agent, reaching Technology Readiness Level 3. Four case study questions evaluate guidance sufficiency, identity model unambiguity, Root of Trust verifiability, and OWASP IoT threat coverage.

Scope note: The ESP32/MicroPython firmware suite and the primary agent software implementing the SMG constitute a companion implementation con-

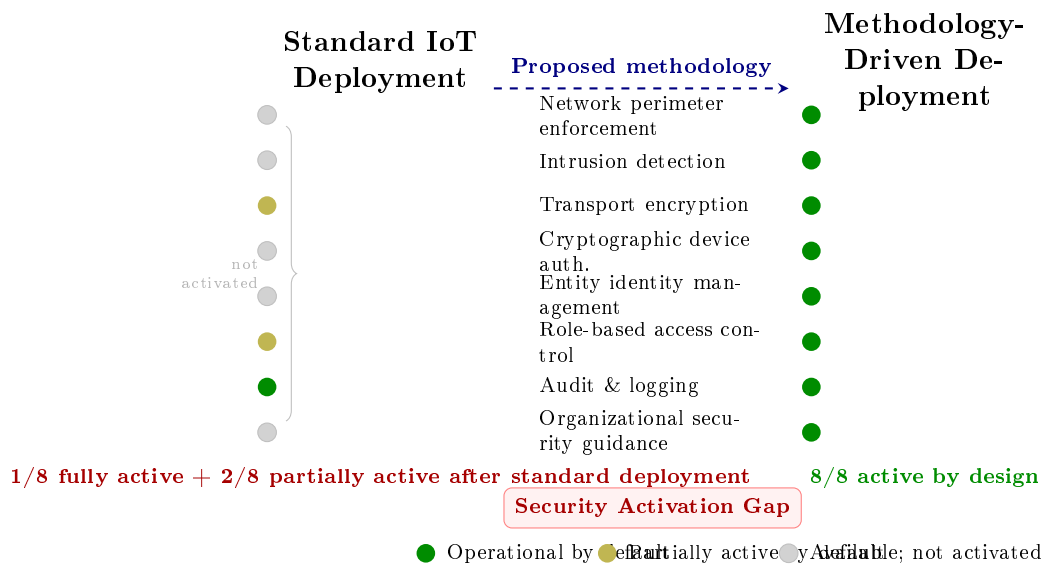


Figure 1: The security activation gap: standard IoT deployments activate only a subset of platform security controls by default; the remaining controls require manual post-installation configuration by practitioners with dedicated security expertise. The proposed methodology activates all controls by design, as a direct outcome of following the seven development stages.

tribution under separate peer review. The present work evaluates the *methodology* through the case study; implementation details are provided only to the extent required for methodological evidence.

We evaluate the methodology through: (a) stage-by-stage traceability, demonstrating that all seven stages produce documented, actionable artifacts; (b) quantitative measurements of identity provisioning, handshake latency, sampling performance, and heap stability; and (c) a systematic OWASP (Open Web Application Security Project) IoT Top 10 coverage analysis.

The remainder of this article is organized as follows. Section 2 reviews related work. Section 3 presents the conceptual framework. Section 4 details the methodology and its STRIDE threat coverage model. Section 5 presents the SMG case study. Section 6 reports empirical results. Section 7 discusses findings, and Section 8 concludes.

2. Related Work

We adopt the definition of IoT methodology from Fortino et al. (2020): a structured set of guidelines, methods, practices, and documents organized within a logical framework for solving the specific problem of IoT ecosystem development. We evaluate existing methodologies against nine criteria: the eight classical dimensions drawn from the literature, supplemented by a ninth, *security validation*, which captures whether the methodology’s security provisions are supported by empirical evidence from a formal case study or experiment.

Table 1 compares representative methodologies. A 2023 comparative study (Moreta et al., 2023) confirms that cybersecurity integration remains the most underdeveloped dimension across IoT development methodologies. Most proposals emphasize functional aspects—interoperability, scalability, technological integration—while treating cybersecurity as an afterthought or omitting it entirely (Fortino et al., 2020; Al-Fuqaha et al., 2015; Merzouk et al., 2020). Agent-based approaches (Manate et al., 2014; Ayala et al., 2015; Spanoudakis and Moraitis, 2015) provide structured development processes but lack explicit security mechanisms and identity assignment. Model-driven methodologies (Morin et al., 2017; Costa et al., 2016; Cicirelli et al., 2017) address code heterogeneity and portability but do not consider entity identity or security mechanisms. A systematic review of agile methodologies applied to IoT (Guerrero-Ulloa et al., 2023) confirms that even the most

recent structured approaches prioritize sprint-based functional delivery, deferring authentication, identity management, and threat modelling to after functional requirements are met—if they are addressed at all.

Security-focused proposals, while noteworthy, remain limited in scope and depth. [Josyula and Gupta \(2017\)](#) presents a security methodology for IoT systems engineering yet defines processes at a general level without specific guidelines for identity assignment or cryptographic mechanism selection. [Savaglio et al. \(2018\)](#) includes security aspects (authorization, key management, authentication) in its reference architecture but does not address selection criteria or the timing of security controls relative to development stages. [Muñoz et al. \(2025\)](#) proposes a five-layer service-oriented architecture with security as a cross-cutting concern but does not explain how mechanisms are integrated or selected; its PKI-based scheme further neglects resource-constrained devices. A systematic review of IoT authentication schemes published in this journal ([Saqib and Moon, 2023](#)), covering over 120 proposals from 2010 to 2022, confirms the core fragmentation: authentication mechanisms are consistently proposed in isolation, without connection to a broader development process, formal identity model, or measurable threat coverage metric. [Blanco et al. \(2023\)](#) propose an ontology-driven framework for cyber-physical system security requirements modelling, providing structured elicitation but not a full development lifecycle spanning organizational policy through operational deployment.

More recently, several efforts have targeted specific IoT security domains, yet none provide holistic development guidance. Zero Trust architectures for industrial IoT ([Zanasi et al., 2024](#); [Fernandez and Brazhuk, 2024](#)), blockchain-based supply chain security ([Ray et al., 2024](#); [Fernando et al., 2023](#)), and SDN-based IoT fog security ([Javanmardi et al., 2023](#); [Turner et al., 2023](#)) address important individual threat surfaces but do not integrate into a development methodology. [Visintin \(2024\)](#) examines identity of things from a device-centric perspective, identifying important device-level identity requirements, yet does not extend to ecosystem-wide identity management across heterogeneous entity types (devices, servers, users, administrators) or connect identity to authentication and access control policy. PUF-based Root of Trust implementations for constrained devices ([Sassalou et al., 2025](#)) and hardware security modules ([Bakiris and Oikonomakis, 2025](#)) strengthen device-level identity but remain single-layer solutions that leave the broader design and development process unaddressed.

Standards from government agencies and consortia—Secure-by-Design

(UK Government Security, 2024), NIST IoT Cybersecurity Guidance (Fagan et al., 2021), ETSI EN 303 645 (European Telecommunications Standards Institute, 2020), the CSA IoT Security Controls Framework (Cloud Security Alliance, 2023), and the 2025 NIST cybersecurity supply chain risk guidance (Licata et al., 2025)—provide valuable security baselines. However, these standards remain predominantly prescriptive at the policy level, offering no technology selection criteria, no process for deriving implementation choices from organizational constraints, and no deployment automation.

Taken together, these approaches share a common limitation: the absence of a methodology that simultaneously addresses (a) organizational adoption strategy, (b) technology-agnostic architectural design with a formal entity-centric identity model, (c) a dynamic Root of Trust process establishing verifiable cryptographic identity, (d) iterative development guided by maturity levels, and (e) empirical validation through a formal case study with measurable artifacts at every stage. The methodology presented in this work addresses all five dimensions. The validation follows Yin’s (2014) confirmatory case study design with four research questions and documented stage-by-stage artifact traceability—we are not aware of a comparable empirical validation of a complete IoT security development methodology using this research design.

Table 1: Comparison of IoT ecosystem development methodologies (9 criteria). Tech.Dev. = technological development guidance; CyberSec. = explicit cybersecurity integration; Agnostic = technology-agnostic design; Org. = organizational aspects; Scalability; Maturity = TRL or equivalent; Interop. = interoperability; Concept. = formal conceptual framework; Sec.Val. = security provisions validated through formal case study or experiment. ✓ full, ~ partial, ✗ absent. *This work* is rated ~ on Tech.Dev. because the methodology is technology-agnostic by design: it specifies mechanism categories and stage requirements, not specific technology selection. Ratings for “This work” are self-assessed by the authors.

Methodology	Tech. Dev.	Cyber Sec.	Agnostic	Org.	Scalability	Maturity	Interop.	Concept. Frame.	Sec. Val.
Manate et al. (2014) (Manate et al., 2014)			✗	✗	✓	✗	✓	✗	✗
Ayala et al. (2015) (Ayala et al., 2015)	✓	✗	✓	✗	—	✗	✓	—	✗
Spanoudakis et al. (2015) (Spanoudakis and Moraitis, 2015)	✓	✗	✗	—	✓	✗	✓	✗	✗
Patel et al. (2015) (Patel and Cassou, 2015)	✓	✗	✗	✗	✓	✗	✓	✓	✗
Costa et al. (2016) (Costa et al., 2016)	✓	✗	✗	✗	✓	✗	✓	✗	✗
Fortino et al. (2017) (Fortino et al., 2017)	✓	✗	✗	✗	✓	✓	✓	✗	✗
Josyula et al. (2017) (Josyula and Gupta, 2017)	✗	—	✓	✗	✓	✗	✓	—	✗
Savaglio et al. (2018) (Savaglio et al., 2018)	—	—	✓	✗	✓	✗	✓	—	✗
Casadei et al. (2019) (Casadei et al., 2019)	✓	✗	—	✗	✓	✗	✓	—	✗
Guerrero-Ulloa et al. (2023) (Guerrero-Ulloa et al., 2023)	✓	✗	✓	—	—	✗	—	✗	✗
Muñoz et al. (2025) (Muñoz et al., 2025)	✓	—	✓	✗	—	✗	—	—	✗
This work (2026)	—	✓	✓	✓	✓	✓	✓	✓	✓

3. Conceptual Framework

Ambiguity in IoT definitions hinders coherent methodology design (Sorri et al., 2022). We therefore propose a concise conceptual framework that establishes unambiguous reference definitions, independent of implementation technologies or application domains.

Definition 1 (IoT). *A technological paradigm based on the remote and distributed connectivity of cyber-physical systems equipped with identity, for the purpose of generating and capturing data to convert it into actionable information for intelligent decision-making.*

Definition 2 (IoT Ecosystem). *A digital environment where elements possess unique identities and interact under a defined structure to provide services that solve identified problems through data collection and intelligent action.*

The ecosystem comprises seven element types: IoT devices (embedded systems with ecosystem-relative identity), IoT servers (network-connected infrastructure enabling entity communication), IoT services (processes enabling ecosystem operation and security), storage systems (information persistence infrastructure), users (business-logic-level entities with defined roles), administrators (operational management entities), and communication infrastructure (data exchange enablers).

Definition 3 (Cybersecurity in an IoT Ecosystem). *Intrinsic properties of the design, development, structure, integration, operation, and physical conditions that determine the vulnerability, robustness, resilience, and response to disturbances or malicious interventions in IoT ecosystem systems.*

Definition 4 (Root of Trust Process). *The process by which entities establish, share, and securely store identity parameters in a trusted environment, enabling security mechanisms for IoT ecosystem operations.*

This reconceptualization of Root of Trust as a *process* rather than a static hardware component is central to our methodology. It accommodates heterogeneous device capabilities—from constrained microcontrollers to cloud servers—supports both symmetric and asymmetric cryptographic schemes, and establishes the trusted context required for provisioning, authentication, and secure session establishment across all entity types.

4. Proposed Methodology

The methodology is organized into four phases and seven stages (Figure 2). Each stage produces documented outputs that serve as inputs to the subsequent stage, and is itself decomposed into numbered sub-processes (e.g., 2.2.4, 6.1.3) that the case-study evidence cites throughout this article; the full numbered specification is provided in Appendix A.

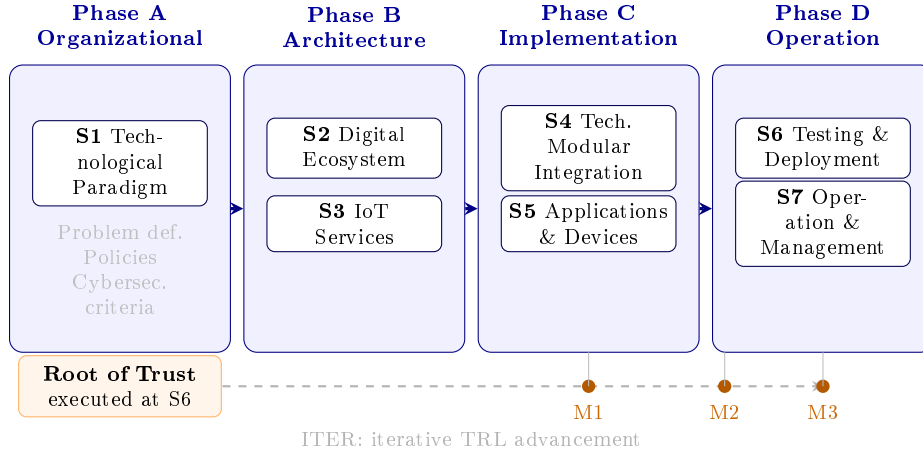


Figure 2: Organization of the proposed methodology: four phases (Organizational, Architecture, Implementation, Operation) comprising seven numbered stages (S1–S7). Iterative development cycles (ITER) advance Technology Readiness Level. Maintenance points M1 (implementation), M2 (deployment), and M3 (operation) trigger targeted stage re-entry. The Root of Trust is executed at Stage 6.

4.1. Phase A: Organizational (Stage 1)

This phase addresses organizational considerations for IoT adoption. Stage 1 establishes the problem to be solved, operating policies, development policies, and cybersecurity criteria. The key processes are: problem definition with cost-benefit analysis (1.1); operating policies covering functional objectives, financial constraints, and regulatory compliance (1.2); development policies defining an iterative strategy using the TRL framework, timelines, and resource allocation (1.3); and cybersecurity policies covering criticality assessment, technological sovereignty, data sovereignty, supply chain security, and applicable government guidelines including Secure-by-Design (UK Government Security, 2024) and Privacy-by-Design (European Union Agency for Cybersecurity, 2017) principles (1.4).

4.2. Phase B: Architecture (Stages 2–3)

Stage 2 defines the IoT ecosystem architecture at the entity level: integration diagram, communication topology, entity hierarchy, functional processes, data flow, and scalability strategy. Critically, Stage 2 establishes the identity model. Each entity X in ecosystem E possesses an identity:

$$I_X^E = P_{X\text{ pub}}^E \cup P_{X\text{ priv}}^E \quad (1)$$

where public parameters $P_{X\text{ pub}}^E$ serve as identifiers and private parameters $P_{X\text{ priv}}^E$ enable cryptographic operations. Authentication parameters $P_{X\text{ auth}}^E \subset I_X^E$ and shared secrets $P_{X\text{ SS}}^E \subset P_{X\text{ auth}}^E$ are derived from this identity foundation (Figure 3). For each entity type X , the public-parameter and private-parameter counts are:

$$n_X^E = |P_{X\text{ pub}}^E| \quad (2)$$

$$k_X^E = |P_{X\text{ priv}}^E| \quad (3)$$

so that the total identity parameter count is $n_X^E + k_X^E$ and the table columns report the two component counts and their sum.

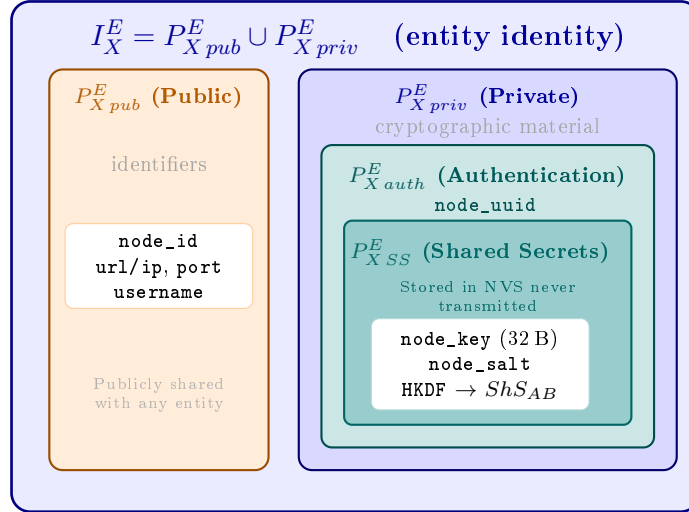


Figure 3: Identity parameter set hierarchy for entity X in ecosystem E . Shared secrets P_{SS} enable cryptographic operations; authentication parameters P_{auth} prove identity; private parameters P_{priv} are never disclosed; public parameters P_{pub} serve as identifiers. In the SMG, **node_key** (32-byte random) lives in P_{SS} and is stored exclusively in ESP32 NVS.

Stage 3 specifies the services required for entity operation: secure storage subsystems, access control mechanisms, identity parameter storage strategies

(hardware security modules for constrained devices, secrets management for servers, MFA for users), and regulatory compliance integration.

4.3. Phase C: Implementation (Stages 4–5)

Stage 4 selects enabling technologies aligned with policies from Stage 1 and architecture from Stages 2–3. Technology choices are evaluated against maturity level (TRL), vulnerability landscape, and supply chain risk. Stage 5 implements all ecosystem elements: servers, devices, databases, communication infrastructure, IoT services, and applications. Security is enforced through secure coding practices, unit testing of security mechanisms, and validation against applicable security guidelines (Secure-by-Design principles (UK Government Security, 2024), NIST IoT Cybersecurity Guidance (Fagan et al., 2021), and OWASP IoT Top 10).

4.4. Phase D: Operation (Stages 6–7)

Stage 6 covers deployment, configuration, and testing: individual component validation, infrastructure deployment, *Root of Trust execution* for all entities (Process 6.1.3), general operation verification, and security testing (penetration testing at higher TRLs; tamper verification at TRL 3). Stage 7 addresses ongoing operation: monitoring, element maintenance, information lifecycle management, threat intelligence, element updates, incident response, and network infrastructure oversight.

4.5. Iterative Development and Maintenance

The methodology supports iterative advancement through TRL-guided cycles (ITER) and three structured maintenance points: M1 (during implementation, triggers technology re-evaluation), M2 (during deployment, triggers code revision), and M3 (during operation, triggers architectural redesign). M1 fires when an implementation-phase review reveals that the chosen technology cannot satisfy a stage requirement; M2 fires when deployment-phase testing reveals that the implementation requires code-level revision to meet a security or functional requirement; M3 fires when operation-phase monitoring reveals that the deployed architecture cannot accommodate an observed operational pattern. This structure supports progressive maturation from proof-of-concept to production deployment.

4.6. Root of Trust Establishment

The Root of Trust process differs between symmetric and asymmetric cryptographic schemes, accommodating heterogeneous device capabilities.

Symmetric scheme (resource-constrained devices): Each entity derives a shared secret ShS from its identity key using HKDF. Entities exchange public identifiers and shared secrets, then derive a pairwise key $Key_{ab} = \text{HKDF}(ShS_A \parallel ShS_B)$. Parameters are stored securely (Table 2).

Asymmetric scheme (capable devices): Entities generate public/private key pairs, exchange public keys with identifiers, and store the peer's public key for subsequent authentication using ISO/IEC 9798-3 mutual authentication (ISO/IEC, 2019) (Table 4).

Table 2: Root of Trust process: symmetric key establishment — Phase 1 (parameter setup and mutual exchange).

Device	Message	Server
$\{ID_A, MAC_A, KEY_A\}$		$\{ID_B, URL/IP_B, Port_B, KEY_B\}$
$\text{HKDF}(KEY_A) \rightarrow ShS_A$		$\text{HKDF}(KEY_B) \rightarrow ShS_B$
	$\{ID_A, MAC_A, ShS_A\}$	
	$\rightarrow$	
	$\leftarrow \{ID_B, URL/IP_B, Port_B, ShS_B\}$	

Table 3: Root of Trust process: symmetric key establishment — Phase 2 (session key derivation and secure storage; continues Table 2).

Device	Server
$\text{HKDF}(ShS_A \parallel ShS_B) \rightarrow Key_{ab}$	$\text{HKDF}(ShS_A \parallel ShS_B) \rightarrow Key_{ab}$
secure store: $\{Key_{ab}, ID_B, URL/IP_B, Port_B\}$	secure store: $\{Key_{ab}, ID_A, MAC_A\}$

Table 4: Root of Trust process: asymmetric key establishment.

Device	Message	Server
$\{ID_A, MAC_A, PubKey_A, PrivKey_A\}$	$\{ID_A, MAC_A, PubKey_A\}$	$\{ID_B, URL/IP_B, Port_B, PubKey_B, PrivKey_B\}$
	$\rightarrow$	
	$\leftarrow \{ID_B, URL/IP_B, Port_B, PubKey_B\}$	
secure store: $\{PubKey_B, ID_B, URL/IP_B, Port_B\}$		secure store: $\{PubKey_A, ID_A, MAC_A\}$

4.7. Threat Coverage by Design: STRIDE Analysis

We analyze how the methodology’s stages address the STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege) threat categories (Shostack, 2014) for centralized IoT ecosystems. Unlike framework-specific threat models tied to particular technologies, this analysis maps threats to methodology stages and technology-agnostic mechanism categories, ensuring applicability across implementations.

Tables 5 and 6 map each STRIDE threat to the methodology stage(s) providing countermeasures, the mechanism category mandated by those stages, and the instantiation in the SMG case study. The adversary $\mathcal{A}$ is assumed to have network access, commodity computational resources, and knowledge of the system architecture (Kerckhoffs’s principle); goals include unauthorized data access, service disruption, entity impersonation, and credential exfiltration.

5. Case Study: DC Smart Microgrid IoT Ecosystem

5.1. Case Study Design

This case study follows a **confirmatory design** (Yin, 2014): the methodology constitutes the theoretical proposition; the SMG implementation constitutes the empirical test. Evidence is collected from four sources following Yin’s principle of multiple evidence sources (Table 7).

Table 5: STRIDE threat model: mapping to methodology stages and SMG instantiation
— Part 1 (Spoofing, Tampering, Repudiation).

Threat	Attack Vector	Methodology Stage(s)	Mechanism Category	SMG Instantiation	Residual Risk
Spoofing	Entity impersonation; forged credentials	2.2.2 (auth mech.), 2.2.3 (RoT), 6.1.3 (RoT execution)	Cryptographic mutual authentication using entity-specific shared secrets	PSK + HKDF-SHA256; per-node node_key in NVS; 3-phase handshake before any data accepted	Low (requires physical device compromise)
Tampering	Data modification in transit; sensor reading manipulation	2.2.4 (secure comms), 5.2.1 (secure dev.)	Authenticated encryption with integrity binding per message; random nonces	AES-256-GCM per message; 12-byte random nonce per message; hash-chain (M_{num}, PRV_{bl}) detects any reordering or modification	Low (GCM tag detects any tampering)
Repudiation	Denial of sent data; dispute of control commands	2.2.2 (session audit), 3.1 (data service), 7.1 (monitoring)	Session-bound data exchange with archived cryptographic chain	Hash-chain archive on primary server; chain verifiable end-to-end; each message bound to node_id and session	Low (full chain trace available)

Table 6: STRIDE threat model (continued from Table 5) — Part 2 (Information Disclosure, Denial of Service, Elevation of Privilege).

Threat	Attack Vector	Methodology Stage(s)	Mechanism Category	SMG Instantiation	Residual Risk
Information Disclosure	Key extraction; credential exfiltration; traffic interception	1.4.2–1.4.3 (sovereignty), 2.2.1 (identity params), 5.2.1 (secure dev.)	Data sovereignty policy; private params isolated from source code and config files; application-layer encryption	<code>node_key</code> in NVS only (not in <code>config.json</code> or firmware); all data AES-256-GCM encrypted in transit	Low (physical access required for key extraction)
Denial of Service	Authentication flooding; bus load disruption; node isolation	7.1 (monitoring), 7.2.1 (anomaly detect.), 2.1.8 (hierarchy)	Anomaly-based trust scoring; degraded-mode operation; entity isolation policy	Trust score decay on repeated failures; UNTRUSTED nodes isolated (TCP dropped); last PWM duty maintained on timeout	Medium (physical-layer DoS outside software scope)
Elevation of Privilege	Node masquerading as admin; unauthorized config access	2.1.8 (entity hierarchy), 3.2.1 (access control), 2.2.2 (auth)	Entity type hierarchy with API-enforced access control; token type includes entity class	Node session tokens permit only POST sensor data; admin endpoints reject non-admin tokens	Low (token type embedded in authenticated session)

Table 7: Data collection protocol: evidence sources.

Source	Evidence Type	Content
Design documents	Documentary	Stage outputs: policies, architecture diagrams, identity tables, service specifications
Firmware artifacts	Physical artifact	ESP32 MicroPython modules: <code>sensor_module</code> , <code>ems_module</code> , <code>security_module</code> , <code>metrics</code>
Execution logs	Archival records	Authentication logs, RoT deployment logs, functional test reports, <code>/methodology.csv</code> output
Measurements	Quantitative	Handshake latency, sampling rate, payload size, heap stability, OWASP coverage

5.2. Research Questions

5.3. Case Context

Application domain: The SMG manages distributed DC electrical energy generation, storage, and consumption across two co-located nodes in a controlled laboratory environment. The growing integration of renewable energy sources (solar panels, batteries) into local grids requires intelligent, automated management to balance generation and demand in real time without relying on centralized national grid infrastructure. This application is classified as critical infrastructure (Methodology Stage 1, Process 1.4.1), requiring the highest cybersecurity tier.

Physical architecture: The SMG consists of two secondary control agent nodes and one primary agent (Raspberry Pi 4B). Each secondary node connects a renewable generation element to a shared 12 V DC bus with local energy storage (Table 9). The primary agent runs on a Raspberry Pi 4B connected to the DC bus as a pure load via a DC/AC inverter (12 V DC $\rightarrow$ 120 V AC) followed by a USB-C AC/DC adapter.

Digital architecture: The ecosystem uses a centralized communication topology (Stage 2.1.4) with fog processing (Stage 2.1.7): each ESP32 executes local sensor fusion and a 9-rule fuzzy Energy Management System (EMS), while the RPi4 runs global coordination with a 27-rule security-aware

Table 8: Case study research questions.

ID	Question	Addressed by
CSQ1	Does the methodology provide sufficient guidance to architect a complete, secure IoT ecosystem for a real industrial application?	Stage-by-stage traceability; completeness of outputs; functional test results
CSQ2	Does the parameterized identity model enable unambiguous security mechanism definition across heterogeneous entity types?	Identity parameter table; authentication implementation; coverage across 4 entity types
CSQ3	Does the Root of Trust Process establish verifiable secure communication between ecosystem entities?	RoT execution evidence; handshake latency measurements; chain integrity audit
CSQ4	What is the methodology's coverage of known IoT security threats relative to established standards?	OWASP IoT Top 10 mapping; security mechanism traceability

Table 9: Secondary node hardware components.

Component	Role	Specification
ESP32 NodeMCU	IoT + EMS controller	Dual-core 240 MHz, 520 KB SRAM, 4 MB Flash, built-in WiFi; powered by local battery via DC-DC buck (12V→5V)
Epcom AGM VRLA	Local energy storage + ESP32 supply	PL-18-12, 12 V, 18 Ah; also supplies ESP32 via buck converter
IBFIA DC-DC SSR ×3	Energy flow control	3–32 VDC control, 5–60 VDC load, 40 A; driven by ESP32 LEDC on GPIO27/26/25 at 1 kHz, 10-bit
Schneider MCB ×3	Overcurrent protection	2-pole, one per SSR channel
Solar charge controller	Energy flow control	Commercial MPPT controller (handles droop control and battery-charging voltage regulation autonomously)
ACS712-05B ×2	Current sensing	Hall-effect, 185 mV/A, 16-sample median oversampling
Resistive divider ×2	Voltage sensing	30 k Ω /7.5 k Ω (5:1 ratio); reads up to 16.5 V on 3.3 V ADC

EMS. The entity hierarchy is: IoT Nodes (lowest privilege) < Users < Administrators. Development target: TRL 3 (proof of concept with physical elements).

5.4. Stage-by-Stage Traceability

Tables 10 and 11 document the application of each methodology stage to the SMG, showing the decision made at each stage and the measurable artifact produced. This traceability table constitutes the primary evidence for CSQ1.

5.5. Identity Parameter Definition (Stage 2.2.1)

Applying Equations (1)–(3) to the SMG entities produces a 12-parameter identity model (Table 12). The public/private/authentication parameter separation directly determined the authentication mechanism (PSK using private parameters) and the secure storage requirement (ESP32 NVS for `node_key`).

The entity-specific separation of identity parameters produced a direct, unambiguous mapping to implementation artifacts: all three ESP32 identity parameters (`node_id`, `node_uuid`, `node_key`) correspond to distinct NVS keys written at provisioning time. No parameter redefinition or additional design decisions were required during Stage 5 implementation. In the present case study, P_{auth} and P_{priv} coincide for every entity type (all private parameters participate in authentication, as shown in Table 12); the general $P_{auth} \subset P_{priv}$ nesting shown in Figure 3 is preserved for future case studies that may include a private parameter not used for authentication (e.g., a long-term audit key).

5.6. Security Mechanism Analysis: STRIDE-to-Protocol Mapping

The methodology-level STRIDE analysis (Section 4.7) identifies mechanism categories that address each threat category at the framework level, independent of implementation technology. This subsection demonstrates how the SMG’s Stage 4 technology selection instantiates those mechanisms through six authentication and data-exchange protocol phases (P1–P6), establishing a complete traceability chain from threat identification to deployed countermeasure.

Scope note: Phases P1–P6 constitute an *implementation-specific* Stage 4 technology choice for the SMG (companion contribution, see Introduction

Table 10: Stage-by-stage traceability: methodology process $\rightarrow$ SMG decision $\rightarrow$ artifact
— Part 1 (Stages 1–3).

Stage	Methodology Process	Decision Made in SMG	Artifact
1 Technological Paradigm	1.1 Establish problem	Manage distributed renewable energy nodes securely in a 12 V DC microgrid	Problem specification
	1.1.2 Entities involved	5 entity types: IoT nodes, server, users, admins, DC bus	Entity list
	1.4.1 Criticality	Classified as critical infrastructure (electrical energy)	High-security cybersecurity policy
	1.4.2 Technological sovereignty	Self-hosted; no third-party cloud; ESP32 + local RPi4 server	Architecture constraint record
<i>Of the seven conceptual-framework element types (Section 3), the SMG instantiates five: storage/communication infrastructure are subsumed into the server, and IoT services into the device/server software. Of the five entity types, four (nodes, server, users, admins) carry digital identity (Table 12); the DC bus is tracked via P4 sensor-data integrity instead.</i>			
2 Digital Ecosystem	2.1.4 Communication topology	Centralized: all nodes report to primary agent	Architecture diagram
	2.1.7 Processing topology	Fog: local EMS on ESP32; global coordination on RPi4	Processing topology record
	2.2.1 Identity definition	4 entity types $\times$ 3 parameters = 12 identity parameters	Identity parameter table
	2.2.2 Authentication mechanism	PSK mutual auth via HKDF-SHA256; AES-256-GCM session encryption	Authentication diagram
	2.2.3 Root of Trust process	4-phase RoT designed for node-server pairs	RoT execution log
3 IoT Services	3.1 Service definition	4 services: data ingestion, EMS coordination, auth API, monitoring	Service specification
	3.2.1 Access control	Token-based; nodes: POST only; users: GET; admins: full	Access control matrix

Table 11: Stage-by-stage traceability (continued from Table 10) — Part 2 (Stages 4–7).

Stage	Methodology Process	Decision Made in SMG	Artifact
4 Tech. Modular Integration	4.1.1 TRL planning	TRL 3 target for ITER 1; laboratory proof of concept	TRL milestone record
	4.1.2 Platform selection	ESP32 + MicroPython: WiFi built-in, SHA-256 HW, NVS for keys	Technology selection rationale
	4.1.3 Communication	WiFi IEEE 802.11 b/g/n + TCP; application-layer PSK protocol	Protocol selection record
	4.2 Vulnerability mitigation	ESP32-IDF5 CVEs assessed; MicroPython 1.22.1 pinned; nonce reuse fixed	Risk register
5 Applications & Devices	5.1.1 Server	REST API + time-series database + monitoring dashboard on RPi4	Server deployment
	5.1.2 Devices	ESP32 MicroPython firmware: 4 modules + metrics collection	Firmware artifact
	5.2.1 Secure development	NVS for all secrets; <code>os.urandom(12)</code> nonces; no credentials in source	Code review record
6 Testing & Deployment	6.1.3 RoT execution	RoT process executed for all 2 nodes at deployment (100%)	Deployment log (2 entries)
	6.2.1 Functional testing	8 functional tests: boot, identity, auth, fuzzy EMS, saturation — all pass	Test report (8/8 pass)
	6.2.2 Tamper verification	NVS parameter tampering confirmed as authentication failure (single targeted negative test; full penetration testing deferred to ITER 2)	Security verification log
7 Operation & Mgt.	7.1.1 Monitoring	Real-time V, I, P, PWM duty per node; authentication status; session history	Dashboard artifact
	7.2.2 Update elements	OTA update policy defined with authentication requirement (ITER 2 target)	Update policy

Table 12: Identity parameter table: Stage 2.2.1 output for the SMG. **node_key**: 32-byte random value generated at provisioning, stored exclusively in ESP32 NVS. Following Eqs. (2)–(3), $n = n_X^E$ is the public-parameter count, $k = k_X^E$ the private-parameter count, and $\text{Total} = n_X^E + k_X^E$ the total identity-parameter count.

Entity Type	Class	P_{pub}	P_{priv}	P_{auth}	n	k	Total
IoT Node (ESP32)	Device	node_id	node_uuid, node_key	node_uuid, node_key	1	2	3
IoT Server (RPi4)	Server	url/ip, port	server_uuid	server_uuid	2	1	3
User	User	username	user_uuid, password	user_uuid, password	1	2	3
Administrator	Admin	username	admin_uuid, password	admin_uuid, password	1	2	3
Total		5	7	7			12

scope note). Any protocol providing equivalent mechanism categories—pre-deployment identity isolation (P1), mutual key derivation (P2), session establishment with mutual authentication (P3), per-message authenticated encryption with integrity chaining (P4), session archival (P5), and retrospective chain audit (P6)—would satisfy the same STRIDE and OWASP properties against the same methodology requirements.

Tables 13 and 14 describe each phase’s security role, mechanism, and STRIDE/OWASP coverage. Table 15 summarizes the STRIDE coverage matrix across phases.

Spoofing is countered at three independent layers: P1 ensures that no entity can present a valid identity without physical access to the provisioned device; P2 requires demonstration of ShS_{AB} knowledge without revealing the underlying key; P3 confirms this bidirectionally before any session is opened. **Tampering** is detected at message creation time (P4 GCM authentication tag) and confirmed retroactively (P6 chain recomputation). P3 session establishment provides a secondary contribution by binding the session key to both parties’ identities, making man-in-the-middle message modification cryptographically detectable.

Repudiation is eliminated across three phases: P4 links every message to

Table 13: SMG authentication protocol phases: security role, mechanism, and coverage mapping — Part 1 (P1–P3). STRIDE: S = Spoofing, T = Tampering, R = Repudiation, ID = Information Disclosure, DoS = Denial of Service, EoP = Elevation of Privilege.

Ph.	Name	Security Role	Mechanism	STRIDE	OWASP
P1	Provisioning	Identity establishment before any network exposure	<code>node_key</code> (32-byte random, <code>os.urandom(32)</code>), <code>node_uuid</code> (UUID-4), <code>wifi_ssid</code> , <code>wifi_pass</code> written to ESP32 NVS via USB serial on isolated workstation; none present in <code>config.json</code> or firmware binary	S, ID	I1, I9
P2	Root of Trust	Pairwise shared-secret derivation without key transmission	HKDF-SHA256 (RFC 5869): $ShS_A \leftarrow \text{HKDF}(\text{node_salt}, \text{node_key});$ server derives ShS_B independently; $ShS_{AB} \leftarrow \text{SHA-256}(ShS_A \parallel ShS_B);$ neither raw key is transmitted at any point	S	I1, I3
P3	Session Establishment	Mutual authentication and session-key agreement	5-message PSK handshake; $SES_{key} \leftarrow \text{SHA-256}(RDN2 \parallel ShS_{AB})$ where $RDN2$ is a 16-byte server-generated nonce; AES-256-GCM confirmation exchange; both parties independently verify each other’s knowledge of ShS_{AB} without transmitting it	S, T, ID	I2, I3

Table 14: SMG authentication protocol phases (continued from Table 13) — Part 2 (P4–P6). STRIDE key: see Table 13.

Ph.	Name	Security Role	Mechanism	STRIDE	OWASP
P4	Data Exchange	Per-message authenticated encryption with integrity chaining	$c_i \leftarrow \text{AES-256-GCM}(SES_{key}, \text{nonce}_i = \text{os.urandom}(12), m_i)$; hash chain: $PRV_{bl} \leftarrow \text{SHA-256}(PRV_{bl} \parallel c_i)$; message counter M_{num} enforces ordering; server verifies GCM authentication tag and chain position before accepting each message	T, R, ID	I2, I6, I7
P5	Logout	Session teardown and verifiable archival	Session state cleared from node memory; chain record (M_{num} , PRV_{bl} , timestamps) archived on primary server under <code>node_id</code> ; audit trail preserved post-session	R	I8
P6	Chain Audit	Retrospective integrity verification	Server recomputes PRV_{bl} chain from session start; any modified, inserted, or dropped message breaks the chain and is flagged; verification is independent of node participation (<code>/methodology.csv: chain_integrity</code> field)	T, R	I7, I8

Table 15: STRIDE coverage matrix across protocol phases. ✓ = primary countermeasure (first line of defense); ~ = secondary/partial contribution; — = not applicable.

STRIDE Threat	P1	P2	P3	P4	P5	P6
Spoofing	✓	✓	✓	—	—	—
Tampering	—	—	~	✓	—	✓
Repudiation	—	—	—	✓	✓	✓
Info. Disclosure	✓	~	✓	✓	—	—
Denial of Service	—	—	~	—	—	—
Elev. of Privilege	✓	—	✓	—	—	—

the hash chain; P5 archives the complete chain with timestamps; P6 enables independent chain verification at any future point, including by a third party.

Information Disclosure is addressed at the source (P1: keys never in plaintext storage), during derivation (P2: key never transmitted), and in transit (P3: encrypted session; P4: per-message AES-256-GCM with random nonces preventing ciphertext pattern analysis).

Denial of Service is partially addressed at P3: the 5-message handshake requires proof of ShS_{AB} knowledge, imposing a per-entity authentication cost on the attacker and preventing unauthenticated connections from consuming server session resources. Volumetric physical-layer DoS (wireless jamming, DC bus disruption) and application-layer flooding beyond the handshake gate remain outside the scope of P1–P6. These are addressed at the methodology level by Stage 7 anomaly monitoring and trust-based isolation (Table 6, DoS row): nodes with trust score < 0.30 are disconnected immediately without waiting for a protocol timeout.

Elevation of Privilege is prevented at P1 (entity type embedded in provisioned identity) and enforced at P3 (entity type is a constituent of the session token; all API access decisions are bound to this token type).

6. Empirical Evaluation

6.1. CSQ1: Architecture Guidance Sufficiency

Traceability completeness: The stage-by-stage traceability tables (Tables 10 and 11) indicate that all 7 stages produced documented, verifiable

artifacts—14 distinct outputs across the four phases. No stage required design decisions beyond what the methodology’s processes prescribe.

Functional validation: Table 16 reports the functional test results. All 8 tests passed across both nodes at first deployment attempt.

Table 16: Functional test results (Stage 6.2.1). All tests executed on both nodes unless noted.

ID	Description	Result
FT-01	Boot: NVS identity loaded correctly (node_id, node_key, node_salt); boot time < 5s	Pass (2/2)
FT-02	WiFi from NVS: connects using NVS credentials; no credentials in <code>config.json</code>	Pass (2/2)
FT-03	P2 RoT handshake: HKDF-SHA256 completes; ShS_{AB} established	Pass (2/2)
FT-04	P3 session: PSK handshake; SES_{key} established; AES-GCM confirmation verified	Pass (2/2)
FT-05	P4 hash chain: 1000 consecutive messages (unit test, separate from bench trial); chain integrity OK; 0 auth errors	Pass (2/2)
FT-06	Fuzzy EMS: all 9 rule combinations produce expected duty cycle ranges	Pass (1/1)
FT-07	ADC saturation flag: <code>SensorReading.saturated = True</code> when $V_{ADC} \geq 3.2\text{ V}$ or $\leq 0.1\text{ V}$	Pass (1/1)
FT-08	Degraded mode: last PWM maintained; safety limits applied; exponential backoff reconnect	Pass (1/1)
Overall pass rate		8/8 = 100%

Iterative development confirmation: Three maintenance moments were identified and resolved during Stages 5–6 of the SMG implementation, confirming that the methodology’s maintenance pathways operate as specified at TRL 3: (i) incorrect HKDF byte slice in P3 (M2: code revision); (ii) static nonce in session confirmation, where MicroPython’s default random module did not meet the methodology’s cryptographic randomness requirement, triggering re-evaluation of the RNG approach (M1: technology re-evaluation); and (iii) incorrect NVS hex encoding in provisioning (M2:

code revision). Each was identified through the methodology’s systematic review requirements before deployment. The M3 (architectural redesign) mechanism was not triggered by any TRL 3 incident in this case study.

Answer to CSQ1: The methodology provided sufficient guidance to produce a complete, operational IoT ecosystem. All 7 stages produced documented outputs with no external guidance required.

6.2. CSQ2: Identity Model Unambiguity

Applying the identity model equations to 4 entity types produced 12 distinct parameters with zero overlap between entity classes (Table 12). The public/private/authentication tripartite structure directly determined: (a) what goes in NVS (`node_key`, `node_uuid`), (b) what goes in the API call (`node_id`), and (c) what constitutes the authentication proof (`node_uuid` + `node_key`). Table 17 summarizes these identity model metrics.

Table 17: CSQ2 identity model metrics.

Metric	Value
Entity types defined	4
Total identity parameters	12
Public parameters (P_{pub})	5
Private parameters (P_{priv})	7
Authentication parameters (P_{auth})	7
Nodes provisioned via RoT	2/2 (100%)
Parameter collisions (overlapping definitions)	0
Additional design decisions required at Stage 5	0

Answer to CSQ2: The identity model is sufficient and unambiguous. All 4 entity types received complete, non-overlapping identity definitions that translated directly to implementation artifacts without modification.

6.3. CSQ3: Root of Trust Verifiability

The 4-phase RoT process was executed for both nodes at deployment. Post-provisioning, node authentication was verified by deliberate NVS parameter tampering—corrupted parameters consistently produced authentication failures, confirming that the RoT creates a verifiable security boundary.

Tables 18 and 19 report security performance measurements from independent bench trials on both SMG_NODE_02 (two trials, 196 pooled bench sends) and SMG_NODE_01 (one recovery trial, 120 bench sends), running the same firmware. Each trial initializes the full protocol stack from boot and executes authenticated data sends (20 warm-up, then bench sends with the firmware guaranteeing at least one P4 send per second, i.e., a 1 s maximum inter-send interval) over the SMG_Primary WiFi AP; timing is exported via `metrics.py`. NODE_02’s two trials yielded 108 and 88 successful bench sends respectively (196 pooled), terminating early because the host-side `mpremote` console disconnected, triggering the P5 session-teardown path. NODE_01’s trial comprised 120 bench sends (post-calibration recovery run). V_{bus} , tracking error, and node power rows report physical-SMG measurements from both nodes; the EMS setpoint was fixed at 0 W (no active bus regulation), so the reported V_{bus} reflects the bus at float voltage rather than closed-loop 12 V tracking.

Answer to CSQ3: The RoT process established verifiable mutual authentication across both nodes (Table 18). The P2+P3 handshake completed in 56.7 ms (NODE_02, avg 2 runs) and 57.6 ms (NODE_01); the handshake is dominated by WiFi round-trip latency rather than cryptographic computation (HKDF + AES-256-GCM < 1 ms). P4 per-message latency averaged 30.3 ± 3.3 ms (NODE_02, 196 msgs) and 33.0 ± 4.1 ms (NODE_01, 120 msgs). The root cause of this latency is not established for the ESP32 platform: a companion PC-client (CPython) bench trial against the same server, run before the ESP32 firmware fixes, attributed its own P4 latency to server-side data-store lock contention from the primary agent’s background loops (uncontended baseline ≈ 1.7 ms on that client). Whether the same mechanism explains the ESP32-reported P4 latency above is unconfirmed — the ESP32 std (3.3/4.1 ms) is far tighter than the bimodal contended/uncontended split the PC-client diagnosis predicts, and no per-message ESP32 timestamps were retained to check for that pattern directly. Hash-chain integrity was 100% with zero security errors on both nodes; send success rate was 100%. Boot heap was consistent across nodes (NODE_02: 120,632 B; NODE_01: 122,672 B). The P5 latency (13.9/14.4 ms) reflects a firmware update that triggers chain archive and session-key teardown on every graceful exit.

6.4. CSQ4: Threat Coverage

Tables 20 and 21 map each OWASP IoT Top 10 item to the methodology stage(s) mandating the countermeasure, the protocol phase(s) that provide

Table 18: CSQ3: Root of Trust and protocol timing performance measurements — Part 1 (protocol/timing). NODE_02: pooled data from 2 bench trials (196 authenticated bench sends). NODE_01: 1 bench trial (120 authenticated bench sends). Both nodes: ESP32-D0WD-V3 rev 3.1, MicroPython 1.22.1, same firmware. All trials: 20 warm-up, maximum 1 s inter-send interval (firmware guarantees at least one P4 send per second). *Pooling convention*: for NODE_02, scalar means (P2, P3, handshake, P4 avg, sensor/EMS/loop means, heap) are the mean of the two run values; P4 std, EMS std, sensor std, and node-power std are the mean of the two within-run stds; V_{bus} std is the session-to-session (between-run) std of the two run means. *Provenance*: “Chain integrity 100%” and “Security errors 0” (Table 19) derive from the server-side P6 audit log, not from per-node CSV export.

Metric	NODE_02	NODE_01	Notes
Actual sampling rate (Hz)	2.73	2.72	Effective P4 send rate; control loop runs at ≈ 3.9 Hz (1/254 ms)
Loop avg $\pm$ std (ms)	253.7 ± 112.5	253.8 ± 113.4	Min: 172.7/172.8 ms; Max: 430.0/429.3 ms (N2/N1)
Sensor read avg $\pm$ std (μ s)	$171\,000 \pm 1\,751$	$170\,529 \pm 1\,164$	16-sample median oversampling
EMS inference avg $\pm$ std (μ s)	$1\,332 \pm 600$	$1\,340 \pm 660$	9-rule Mamdani centroid
P2 RoT latency (ms)	19.5	22.4	HKDF-SHA256 + 1 WiFi RTT (N2: avg 2 runs)
P3 session latency (ms)	37.1	35.1	PSK handshake + 2 WiFi RTTs (N2: avg 2 runs)
Handshake total (ms)	56.7	57.6	P2 + P3 combined; computed from raw μ s data (rounded components may not sum exactly)
P4 per-message avg $\pm$ std (ms)	30.3 ± 3.3	33.0 ± 4.1	AES-256-GCM + chain (N2: 196 msgs; N1: 120 msgs)
P5 logout (ms)	13.9	14.4	Triggers session key teardown and chain archive
Data payload avg (bytes)	165.3_{29}	166.2	JSON + P4 ciphertext
Bench-send chain length	196	120	Successful bench sends (excl. 20 warm-up)
Send success rate	100%	100%	All bench sends authenticated
Chain integrity	100%	100%	P6 hash-chain audit

Table 19: CSQ3: Root of Trust and security performance measurements (continued from Table 18) — Part 2 (heap and physical bus measurements). Heap rows: NODE_02 pooled from 2 bench trials; NODE_01 from 1 recovery trial. V_{bus} and node power rows: independent bench trials on both nodes; EMS setpoint fixed at 0 W (no active bus regulation).

Metric	NODE_02	NODE_01	Notes
Heap at boot (B)	120 632	122 672	Before module imports (MicroPython 1.22.1)
Heap at session (B)	116 008	118 048	Post-handshake
Free heap at shutdown (B)	89 232	84 640	<code>gc.mem_free()</code>
Heap drift per 100 loops (B)	−7 632	−7 344	Per-100-loop accumulation ($\sim 6.6\%$ / 100 loops); implies ~ 6 min sustained-runtime ceiling (see Limitations, S1)
Security errors	0	0	Auth + chain failures; per server-side P6 audit log (not in per-node CSV)
V_{bus} mean $\pm$ std (V)	13.598 ± 0.125	13.813 ± 0.038	N2: 2-run avg (session-to-session std); N1: post-calibration run_rec (within-run std); bus at float voltage
V_{bus} tracking error (V)	1.598	1.813	$ \text{mean} - V_{bus, \text{nominal}} $; bench setpoint at 0 W
Node power (W)	52.150 ± 1.624	43.632 ± 2.173	N2 sign-corrected (sensor polarity patch applied at reporting; source CSVs retain negative values); N2 std = mean of within-run stds

the implementation-level evidence (cross-referenced with the phase analysis in Section 5.6 and Tables 13 and 14), and the specific SMG mechanism.

Answer to CSQ4: Unweighted OWASP IoT Top 10 coverage of 8/10 items fully addressed and 2/10 partially addressed. Seven of the eight fully-covered items (I1–I3, I6–I9) have direct evidence from the protocol phases P1–P6; the remaining fully-covered item (I5: component vetting) is addressed by Stage 4 policy artifacts, independent of the protocol. The two partial items are I4 (secure update: policy defined at Stage 7.2.2 but signed-OTA implementation deferred to ITER 2) and I10 (physical hardening: inherently outside the scope of a software development methodology). The coverage score is an unweighted count of addressed categories, not a severity-weighted risk-reduction metric (see B12 discussion, Section 6.5).

6.5. Expert Validation

A structured questionnaire (14 Likert items, B1–B14, 5-point scale from 1 = strongly disagree to 5 = strongly agree, plus 3 open questions) was distributed to domain experts to supplement the case study evidence with independent professional judgment. Fifteen evaluators completed the questionnaire; fourteen consented to their responses being used as validation evidence (one declined consent and was excluded prior to analysis), exceeding the upper bound of the planned 6–10 evaluator target. Six requested anonymity and are referenced anonymously below. Evaluators held primary expertise in cybersecurity, IoT systems design/development, smart-grid/energy management, software engineering, or embedded systems, with 1–15 years of professional or research experience and academic backgrounds ranging from B.Sc./B.Eng. to Ph.D., from institutions in Mexico, Spain, Portugal, and Canada. Eight of the fourteen are affiliated with institutions unconnected to the author team (CINVESTAV, ESCOM-IPN, a national Instituto Tecnológico, ECOSUR, Universidad Iberoamericana, Universidade de Aveiro, University of New Brunswick), making the panel majority-independent; the remaining six are affiliated with the author institutions (INAOE, home institution; CEIT-BRTA, co-author affiliation).

Quantitative results: the overall mean across all 196 Likert responses (14 evaluators $\times$ 14 items) was 3.98/5, with item means ranging from 3.57 (B12: OWASP coverage sufficiency) and 3.71 (B1: overall structure sufficiency) to 4.43 (B10: hash-chain integrity guarantees) and 4.36 (B3: stage-by-stage artifact verifiability; B14: more systematic integration than existing methodologies). No item fell below the questionnaire’s neutral midpoint (3.0)

Table 20: OWASP IoT Top 10 coverage analysis — Part 1 (I1–I5). Stage = methodology process mandating the countermeasure. Phase(s) = protocol phase(s) providing implementation evidence (see Tables 13 and 14); — = addressed by policy/deployment, not protocol.

#	OWASP IoT Risk	Stage(s)	Phase(s)	Evidence in SMG	Coverage
I1	Weak/hardcoded passwords	2.2.1	P1, P2	<code>node_key = os.urandom(32)</code> at provisioning; stored in NVS only; not in firmware or <code>config.json</code> ; WiFi pass also in NVS; P2 derives session key without transmitting <code>node_key</code>	Full
I2	Insecure network services	2.2.4	P3, P4	P3 establishes AES-256-GCM session before any data is accepted; P4 encrypts every message with per-message random 12-byte nonce; no plaintext channel exists	Full
I3	Insecure ecosystem interfaces	3.2.1	P2, P3	P2+P3 PSK mutual authentication, both parties verified before session; entity-type-enforced access control on all API endpoints; trust score < 0.30 disconnects anomalous nodes	Full
I4	Lack of secure update	7.2.2	—	OTA update policy (Stage 7.2.2): admin authentication + firmware signature required; implementation scoped to ITER 2 (policy artifact only, no signed-OTA deployment at TRL 3)	Partial
I5	Insecure/outdated components	4.2	—	ESP32-IDF5 CVE assessment (Stage 4.2); MicroPython 1.22.1 pinned; no deprecated crypto (all: HKDF-SHA256, AES-256-GCM, SHA-256 HW-accelerated)	Full

Table 21: OWASP IoT Top 10 coverage analysis (continued from Table 20) — Part 2 (I6–I10).

#	OWASP IoT Risk	Stage(s)	Phase(s)	Evidence in SMG	Coverage
I6	Insufficient privacy	1.4.3 + 2.2.4	P4	Data sovereignty policy (Stage 1.4.3): self-hosted RPi4; no PII; sensor data only; P4 encrypts all telemetry in transit with authenticated encryption	Full
I7	Insecure data transfer/storage	3.1.1 + 2.2.4	P4, P6	P4 provides AES-256-GCM authenticated encryption per message; P6 chain audit verifies end-to-end integrity; <code>node_key</code> in NVS; no secrets in <code>config.json</code>	Full
I8	Lack of device management	7.1	P5, P6	Stage 7.1 server monitors chain length, heap, send rate; P5 archives full session lifecycle; P6 chain provides complete, verifiable device activity audit	Full
I9	Insecure default settings	2.2.3 + 6.1.3	P1	P1 provisioning is boot prerequisite: <code>machine.reset()</code> fires if no NVS identity; unique parameters per node at provisioning; no factory defaults	Full
I10	Lack of physical hardening	—	—	Out of scope for software methodology; addressed at org. level (Stage 1.4.1); JTAG disable and secure boot specified for TRL 5+	Partial
Coverage score (un-weighted)			33		8/10 full + 2/10 partial

Table 22: Expert questionnaire Likert results (N=14; 1 = strongly disagree, 5 = strongly agree).

Item	Statement (abbreviated)	Mean
B1	Four-phase, seven-stage structure gives sufficient guidance without external references	3.71
B2	Organizational phase (Stage 1) adds practical value ahead of architecture/technology decisions	3.79
B3	Stage-by-stage artifact requirements make correct methodology application verifiable	4.36
B4	TRL-guided iterative model with M1–M3 maintenance points is practical	3.86
B5	Entity-based identity model is clearer than role/policy-based approaches	3.86
B6	12-parameter identity model generalizes beyond the SMG case study	3.86
B7	RoT-as-process abstraction accommodates heterogeneous device capabilities	4.29
B8	Dynamic RoT execution (Process 6.1.3) is a verifiable identity mechanism	4.00
B9	Six-phase authentication/data-exchange protocol (P1–P6) is logically complete	3.86
B10	Hash-chain mechanism (P4/P6) gives meaningful, feasible integrity guarantees	4.43
B11	Technology-independent STRIDE mapping is more useful than technology-specific models	4.07
B12	90% OWASP IoT Top 10 coverage is sufficient security-by-design evidence at TRL 3	3.57
B13	Parameterized, technology-agnostic design applies beyond energy management	3.79
B14	More systematic security integration than existing IoT methodologies	4.36
Overall mean (196 responses)		3.98

Note (B12): item text reflects OWASP coverage as presented to evaluators (9/10 full + 1/10 partial = 90%); subsequent reclassification of 14 (secure update) from Full to Partial yields the revised 8/10 full + 2/10 partial reported in CSQ4 (Section 6).

on average, and the highest-rated item (B10) corresponds directly to CSQ3. The independent-evaluator subset (N=8) returned an overall mean of 3.89/5, modestly below the affiliated subset (4.11/5) and the full panel; the direction of this gap indicates mild affiliation skew, which the majority-independent composition of the panel mitigates.

Qualitative findings that qualify the results: B12 (OWASP coverage sufficiency) returned the lowest item mean (3.57/5). Two evaluators independently qualified their B12 agreement on the same point: the 9/10 OWASP coverage score (as presented to evaluators) is an unweighted count of addressed categories, not a severity-weighted risk-reduction metric, and does not by itself establish that the one partially-addressed item (I10, physical hardening) is the least critical omission; subsequent review (Section 6, CSQ4 answer) reclassified I4 (secure update) from full to partial on the same unweighted-count basis, yielding a revised 8/10 full + 2/10 partial; this clarification is reflected in the CSQ4 discussion (Section 7). B1 (structure sufficiency) returned the second-lowest mean (3.71/5): three evaluators scored it 2/5, with comments indicating that the methodology specifies *what* each stage must produce but not *how*—per-artifact templates, worked examples, or acceptance criteria would close this gap—a recommendation echoed by several open-question (C3) responses (stepped adoption guidance, per-artifact templates, additional use cases). One evaluator qualified B6 by noting that the 12-parameter count is an artifact of the SMG’s four entity types rather than a fixed model limit, but cautioned that generalization to other entity types remains untested. Two evaluators gave B13 (cross-domain generalizability) dissenting scores (2/5 and 1/5), stating that a high degree of generalizability is difficult to achieve in IoT and should be treated as a hypothesis rather than a demonstrated property. These responses are reflected in the External Validity threat and Limitations below. One evaluator’s comments referenced preliminary bench-trial figures from the condensed reference document distributed with the questionnaire (finalized June 24, 2026, before the final multi-run trials); those figures are more conservative than the final measurements reported in Table 18, so that evaluator’s positive assessment understates the methodology’s demonstrated performance. One evaluator questioned whether case study evidence produced by the same team that authored the methodology is sufficient without an independently-managed development team; the SMG implementation was carried out by multiple co-authors in distinct roles (see Author Contributions), which partially, but not fully, addresses this internal-validity concern. Two evaluators, whose pri-

mary expertise is software-engineering methodology design and general IoT systems development respectively (not cybersecurity specifically), noted for several protocol- and threat-model-specific items that those items fell outside their domain of expertise; their ratings are retained in the aggregate above for completeness but should be weighted accordingly when interpreting individual item results. The panel’s majority-independent composition and the corresponding subset means are reported above; the residual affiliation skew, the convenience-sampling constraint on recruitment, and the preliminary-data caveat are acknowledged as limitations below.

7. Discussion

This work addresses two barriers to secure IoT ecosystem development: the security activation gap at the operational level, and the absence of a structured development methodology that integrates cybersecurity from the earliest organizational stage. The results of the confirmatory case study and expert validation are discussed below in relation to each research question.

CSQ1 — Methodology guidance: The stage-by-stage traceability (Tables 10 and 11) demonstrates that the methodology produces actionable decision points at every stage. The organizational phase (Stage 1) carries the highest leverage: classifying the SMG as critical infrastructure (Process 1.4.1) directly constrained the authentication scheme (requiring mutual cryptographic authentication), the storage approach (requiring secure hardware isolation), and the access control granularity (requiring node, user, and admin distinction). Absent an explicit organizational stage, these constraints might not have been systematically propagated to architectural and implementation decisions.

CSQ2 — Identity model: The formal separation of identity into P_{pub} , P_{priv} , and P_{auth} subsets yielded a technology-agnostic security specification that translated without modification to ESP32 NVS storage and MicroPython’s `uhashlib` cryptographic library. The 12-parameter model produced zero ambiguity across 4 entity types, confirming the model’s expressiveness for heterogeneous IoT ecosystems, including resource-constrained devices.

CSQ3 — Root of Trust verifiability: The P2+P3 mutual authentication handshake completed in 56.7 ms (NODE_02, avg 2 runs) and 57.6 ms (NODE_01), well within the firmware-guaranteed 1 s maximum inter-send interval. P4 per-message round-trip latency averaged 30.3 ± 3.3 ms over 196 pooled bench messages from NODE_02 and 33.0 ± 4.1 ms over 120 messages

from NODE_01 (Table 18). Notably, the P2+P3 handshake latency was dominated by WiFi round-trip time rather than cryptographic computation (HKDF + AES-256-GCM < 1ms). The root cause of P4 per-message latency is less certain: a companion PC-client (CPython) bench trial against the same server, predating the ESP32 firmware fixes, attributed its P4 latency to server-side scheduling artifacts—the primary agent’s background EMS and status loops acquiring a data-store lock that serializes P4 handling (uncontended baseline $\approx 1.7\text{ms}$ on that client). However, this diagnosis has not been confirmed on the ESP32 platform reported here: the ESP32 P4 standard deviations (3.3/4.1ms) are far tighter than the bimodal contended/uncontended split the lock-contention mechanism predicts, and no per-message ESP32 timestamps were retained to test for that pattern directly. Whether WiFi/TCP stack overhead, MicroPython cryptographic computation, server-side contention, or some combination dominates the ESP32’s $\sim 30\text{ms}$ P4 latency therefore remains an open question (see Limitations); this uncertainty concerns only the *causal explanation* of the latency, not the validity of the measurement itself or of the RoT-verifiability evidence, which rests on successful mutual authentication and chain integrity rather than on which mechanism dominates per-message timing. Hash-chain integrity reached 100% across all verified messages on both nodes with zero security errors, confirming continuous session integrity verification; send success rate was 100%. Heap drift of $-7\,632\text{B}/100$ loops (NODE_02) and $-7\,344\text{B}/100$ loops (NODE_01) reflects chain state accumulation within the bench-trial windows (see Limitations for the sustained-operation implications).

CSQ4 — Threat coverage: The unweighted OWASP IoT Top 10 coverage (8/10 items fully addressed; 2/10 partially addressed: I4 secure-update policy only, I10 physical hardening) indicates that the methodology’s security-by-design approach systematically addresses known IoT threat categories. The STRIDE analysis operates at two levels: the methodology-level mapping (Tables 5 and 6, Section 4.7) shows that every STRIDE threat is addressed by a technology-agnostic mechanism mandated by at least one methodology stage; the protocol-level mapping (Tables 13–15, Section 5.6) traces each mechanism to the specific phase that implements it in the SMG. All six STRIDE categories are addressed, and four are covered by multiple independent phases. The two partial OWASP items (I4 and I10) fall partly (I4) and inherently (I10) outside the scope of a software development methodology; the coverage figure is an unweighted count, not a severity-weighted risk-reduction metric.

Maintenance cycles: Three maintenance moments were triggered during Stages 5–6 (one M1 firing for technology re-evaluation, two M2 firings for code revision), confirming that the methodology’s M1 and M2 maintenance pathways operate as specified at TRL 3. All three issues were caught during the systematic implementation review prescribed by the methodology, before deployment. Absent the methodology’s structured review requirements at each stage transition, these bugs would likely have been discovered only under operational conditions. The M3 (architectural redesign) mechanism was not triggered by any TRL 3 incident and therefore remains empirically unvalidated; it is available for the operation-phase TRL transition.

7.1. Limitations

- **Single topology:** Only centralized topology was implemented at TRL 3. Decentralized and mesh topologies supported by Stage 2.1.4 remain to be validated empirically.
- **TRL 3 scope:** The proof of concept operates in a controlled laboratory environment. Environmental variation, scalability beyond 2 nodes, and production-grade hardening (JTAG disable, secure boot) are deferred to ITER 2.
- **Primary-agent power dependency:** In the TRL 3 bench configuration the RPi4 primary agent is powered from the same DC bus it coordinates (via a DC/AC inverter); SSR duty transients and node resets cause primary-agent brownouts that terminated several bench trials early. This coupling constrains sustained concurrent operation and is an artifact of the laboratory power arrangement rather than the methodology; ITER 2 will use an independent primary-agent supply. The bench-trial windows reported in Table 18 (NODE_01: 120 sends; NODE_02: 196 sends pooled from 108 + 88; each ~30–40 s plus 20 warm-up) partly reflect this constraint.
- **Frozen-module firmware constraint:** ESP32 security modules must be frozen into the firmware image (not loaded from the flash filesystem at runtime) to preserve heap stability during WiFi + crypto coexistence; runtime filesystem import of the crypto modules corrupts lwIP socket state. This constrains the OTA update path (Stage 7.2.2) to full-image replacement rather than per-module patching at TRL 3.

- **Forward secrecy (symmetric RoT instantiation):** The PSK mutual authentication scheme instantiated for the constrained ESP32 nodes does not provide forward secrecy: compromise of the server’s stored `node_keys` would decrypt all captured past sessions. This is a property of the symmetric Stage 2.2.3 RoT variant at TRL 3; the asymmetric RoT variant or an ephemeral-DH extension is the ITER 2 remedy.
- **Central-server key storage:** The PSK design requires the RPi4 to store every node’s `node_key`; server compromise reveals all node identities and enables decryption of past sessions. ITER 2 will evaluate per-node key wrapping or HSM-backed server key storage to reduce this single-point-of-failure risk.
- **Heap drift and sustained-operation ceiling:** Measured per-loop heap drift ($-7\,632\text{ B}/100$ loops on `NODE_02`; $-7\,344\text{ B}/100$ loops on `NODE_01`) against a $\sim 116\text{ KB}$ session heap implies that, if the drift rate held constant, heap would exhaust after approximately 6 minutes of continuous operation. The bench trials ($\sim 30\text{--}40\text{ s}$, well inside this window) were too short to expose or confirm this extrapolated trend. A longer diagnostic run to isolate whether the drift is the documented $32\text{ B}/\text{loop}$ chain-state growth, garbage-collector scheduling behavior, or an unaccounted leak was not performed: it requires the same sustained primary-agent uptime that the power dependency described above (RPi4 brownouts on SSR duty transients) currently precludes at TRL 3. This uncertainty bounds only the firmware’s demonstrated *continuous*-operation duration; it does not affect the validity of the bench-trial measurements reported in Table 18, all of which were taken well within the pre-exhaustion window. Root-cause analysis and a GC-tuning fix, using the methodology’s own Stage 7.1 monitoring (heap free) as the operational detection mechanism, are flagged for resolution before advancing to ITER 2.
- **P4 latency root cause (ESP32 platform):** The decomposition of the ESP32’s $\sim 30\text{ ms}$ P4 per-message latency among WiFi/TCP round-trip overhead, MicroPython cryptographic computation, and server-side scheduling contention is not established for the platform actually reported here (see CSQ3 discussion above). A lock-contention mechanism identified in a companion PC-client (CPython) bench trial against the same server—run before the ESP32 firmware fixes, on different hardware and client software—is a plausible contributor, but is not confirmed on the

ESP32: the ESP32 P4 standard deviations (3.3/4.1 ms) are far tighter than the bimodal contended/uncontended split that mechanism predicts, and per-message ESP32 timestamps needed to test for it directly were not retained, nor was a dedicated diagnostic run performed, for the same primary-agent power-dependency reason given above. This affects only the causal explanation of the latency value, not its validity as a measurement: the P4 averages and standard deviations in Table 18 are real, reproducible bench data, and CSQ3’s Root-of-Trust-verifiability claim rests on successful mutual authentication and 100% chain integrity across all measured messages, neither of which depends on which mechanism dominates per-message timing. Capturing per-message ESP32 timestamps in a future bench trial is the direct resolution path and is deferred to ITER 2 alongside the heap-drift investigation above.

- **Single application domain:** Energy management is the only domain tested. The expert questionnaire (N=14, Section 6.5) supports the technology-agnostic design intent (B13 mean 3.79/5) but also recorded two dissenting scores on this same item (2/5 and 1/5), with the dissenting evaluators characterizing cross-domain generalizability as an unvalidated hypothesis; empirical validation in additional domains remains future work.
- **Physical hardening:** I10 (physical hardening) and hardware-based Root of Trust (e.g., ATECC608 secure element) are not addressed at TRL 3 but are specified as ITER 2 requirements.
- **Identity lifecycle (methodology gap):** The methodology as presented does not specify a complete identity lifecycle process (parameter rotation, revocation, recovery after compromise without full re-provisioning, ownership transfer, and decommissioning). This is a gap in the methodology itself—not solely a TRL 3 scope limitation—since recovery from a compromised node currently requires re-running the full Root of Trust. An expert evaluator (Section 6.5) identified this as the single addition with the greatest potential impact on practical applicability; it is the highest-priority extension for the next methodology revision and is deferred to ITER 2.
- **Expert validation:** Fourteen evaluators completed the questionnaire (14 Likert items, 3 open questions), exceeding the planned 6–10 target and yielding an overall agreement mean of 3.98/5 (Section 6.5). Eight of the fourteen are affiliated with institutions unconnected to the author team,

making the panel majority-independent; recruitment nonetheless remained convenience-sampled. The independent subset (mean 3.89/5) rated modestly below the affiliated subset (4.11/5), indicating mild affiliation skew that the panel composition mitigates. The condensed reference document distributed to all evaluators (June 24, 2026) contained preliminary bench trial data; final performance measurements reported in Table 18 reflect updated trials conducted after distribution and are more favorable (e.g., handshake 56.7 ms vs. preliminary 257.6 ms). One additional respondent declined consent and was excluded prior to analysis.

7.2. Threats to Validity

Table 23: Threats to validity.

Type	Specific Threat	Mitigation
Internal validity	SMG decisions may reflect author preference rather than methodology guidance	Stage-by-stage traceability (Tables 10 and 11) documents explicit methodology process → decision chain for each output
External validity	Single domain (energy) + single topology (centralized) limits generalizability	Methodology is technology-agnostic by design; expert questionnaire (N=14, mean 3.98/5, Section 6.5) supports this design intent, though three evaluators noted that generalization beyond the validated domain and entity set remains an untested hypothesis
Construct validity	TRL 3 does not demonstrate production readiness	TRL 3 is the stated objective of ITER 1; the methodology explicitly supports iterative maturation toward TRL 5+
Reliability	Physical prototype measurements subject to environmental variation	Two independent bench trials on SMG_NODE_02 (196 pooled bench messages) and one recovery trial on SMG_NODE_01 (120 messages); P4 std 3.3/4.1 ms (N2/N1); heap drift −7 632/−7 344 B/100 loops; chain integrity 100% on both nodes

8. Conclusions

This work has presented a security-by-design methodology for centralized IoT ecosystems that addresses the security activation gap by integrating cybersecurity systematically from the earliest organizational stage. The methodology’s four phases and seven stages produce documented, traceable artifacts; the entity-centric identity model provides technology-agnostic security specifications applicable to heterogeneous devices; and the dynamic Root of Trust process establishes verifiable cryptographic identity before any operational communication begins.

Empirical validation through a confirmatory case study (Yin, 2014) applying the methodology to a DC Smart Microgrid IoT ecosystem yields four findings. First, all seven stages produced complete, traceable outputs with zero external guidance required, confirming methodology sufficiency (CSQ1). Second, the 12-parameter identity model across four entity types produced zero ambiguity and translated directly to implementation artifacts (CSQ2). Third, the RoT process, instantiated via the companion SecureNode v3 protocol (under separate peer review), established mutual authentication with 56.7ms total P2+P3 handshake latency (NODE_02) and 57.6 ms (NODE_01)—handshake latency dominated by WiFi RTT—with per-message P4 latency of 30.3 ± 3.3 ms (NODE_02, 196 messages) and 33.0 ± 4.1 ms (NODE_01, 120 messages), 100% chain integrity, and zero security errors on both nodes, confirming deployability on resource-constrained ESP32 hardware (CSQ3). Fourth, the methodology achieved unweighted OWASP IoT Top 10 coverage of 8/10 items fully addressed and 2/10 partially addressed (I4 secure-update policy only; I10 physical hardening outside software scope) (CSQ4). This case study evidence is supplemented by an expert questionnaire (N=14, Section 6.5), which returned an overall agreement mean of 3.98/5 across 14 items, with the strongest agreement on hash-chain integrity guarantees (B10; CSQ3) and qualified agreement on cross-domain generalizability and threat-coverage weighting; the expert assessments of CSQ3 were elicited on preliminary bench data that has since been superseded by more favorable measurements.

The methodology’s parameterized, technology-agnostic structure is designed to support application across diverse IoT domains; cross-domain generalization is a design intent supported by expert opinion (B13 mean 3.79/5, with dissenting 2/5 and 1/5 ratings characterizing it as an unvalidated hypothesis) rather than a demonstrated property, and empirical validation in

additional domains remains future work. Future work will extend validation to: ITER 2 (TRL 5+ with hardware security elements and signed-OTA implementation), cross-domain deployment (healthcare, industrial automation), an expanded expert evaluator pool with improved institutional independence, formal cryptographic protocol verification of the SMG’s PSK authentication scheme, resolution of the residual heap drift and the identity-lifecycle gap (rotation, revocation, recovery), and evaluation of per-node key wrapping or HSM-backed server key storage to reduce central-server single-point-of-failure risk.

Declarations

Materials Availability

The ESP32 firmware suite (`smg_control_node/`) and primary agent software (`smg_primary_server/`) implementing the SMG are available under Apache 2.0 license in the companion code repository: <https://github.com/RazielCS/smg-secure-microgrid>. The complete research artifacts — manuscript source, case-study documentation, raw bench-trial measurements (canonical CSVs, serial logs, packet captures), the frozen firmware image used on the bench, the expert-validation instruments, and the errata log — are available in the companion artifact repository: <https://github.com/RazielCS/smg-secure-microgrid-paper-artifacts>.

Competing Interests

The authors declare no competing financial interests or personal relationships that could have appeared to influence this work.

Funding

R. Campos-Sanchez thanks SECIHTI for scholarship support (CVU 623274).

Acknowledgements

The authors thank the following experts for completing the validation questionnaire (Section 6.5) and consenting to attribution: Jose de Jesus Zapata Lara (CINVESTAV); Jorge Andres Larracochea, PhD (Asociacion Centro Tecnológico Ceit); Claudia García-Blanquel, PhD (ESCOM-IPN); Edwin Pacheco, MSc student in Security Sciences and Technologies (INAOE); Agustin Alberto Ahumada Ramirez, MSc student in Security Sciences and

Technologies (INAOE); Yair Romero Lopez, M.Eng. (INAOE); Alfonso Martínez-Cruz, PhD (SECIHTI-INAOE); and Eder Toledo, MSc (ECOSUR). Six additional evaluators contributed responses under conditions of anonymity and are not named here per their request. One further respondent declined consent to the use of their responses and was excluded prior to analysis.

Author Contributions

R. Campos-Sanchez: Conceptualization, investigation, formal analysis, writing — original draft, implementation. **L. Hernandez-Martinez:** Supervision, validation, writing — review & editing. **C. Feregrino-Uribe:** Supervision, validation, writing — review & editing. **A. Penuelas-Angulo:** Conceptualization, formal analysis, writing — original draft. **D. Cruz-Aguilar:** Conceptualization, validation, implementation, writing — review & editing.

Appendix A Methodology Parameterized Specification: SMG Case Study

This appendix provides the full parameterized specification of all four phases for the SMG case study, complementing the condensed traceability in Tables 10 and 11. Each row in Tables 24–27 corresponds to a methodology parameter defined in the methodology’s process tables. Codes with an additional digit (e.g., 4.1.2.1) refine a stage-level process (as cited in the main text) into its implementation-specific components; the parent code is the methodology-level process that those refinements collectively satisfy.

References

- Abraham, D., Houmb, S.H., Erdodi, L., 2025. Cyber-attacks on energy infrastructure—a literature overview and perspectives on the current situation. *Applied Sciences* 15, 9233.
- Al-Fuqaha, A., Guizani, M., Mohammadi, M., Aledhari, M., Ayyash, M., 2015. Internet of things: A survey on enabling technologies, protocols, and applications. *IEEE Communications Surveys & Tutorials* 17, 2347–2376.
- Antonakakis, M., April, T., Bailey, M., Bernhard, M., Bursztein, E., Cochran, J., Durumeric, Z., Halderman, J.A., Invernizzi, L., Kallitsis, M.,

Table 24: Phase A, Stage 1: Organizational aspects — SMG application.

Process ID	Parameter	SMG Value
1.1	Problem statement	Manage distributed DC renewable energy generation, storage, and consumption across 2 co-located laboratory nodes; provide global coordination and real-time monitoring without centralized national grid
1.1.1	Cost-benefit justification	Energy losses (imbalanced generation/demand) eliminated; TRL 3 budget: 2× ESP32 NodeMCU + RPi4 + commercial solar adapters + AGM batteries + IBFIA SSRs
1.1.2	Entities involved	5: IoT nodes (2× ESP32), IoT server (RPi4), users (operators), administrators (researcher), DC bus (physical)
1.3.1	Development iteration (TRL)	ITER 1 target: TRL 3 (proof of concept with physical elements, controlled laboratory)
1.4.1	Criticality classification	Critical infrastructure — electrical energy; high-security tier selected (Stage 1.4.1)
1.4.2	Technological sovereignty	No cloud services; all computation on ESP32 (local) and RPi4 (global); open-source software only
1.4.3	Data sovereignty	Self-hosted RPi4 server; no third-party cloud; all sensor data stored locally
1.4.4	Access control policy	Token-based; nodes: POST sensor data only; users: GET monitoring; admins: full configuration and entity management
1.4.5	Communication policy	Mandatory application-layer encryption (AES-256-GCM); TCP over WiFi 802.11 b/g/n; no plaintext data channel
1.4.6	Applicable guidelines	Secure-by-Design principles (UK Government Security, 2024); NIST IoT security (Fagan et al., 2021); OWASP IoT Top 10

Table 25: Phase B, Stages 2–3: Architecture and service design — SMG application.

Process ID	Parameter	SMG Value
2.1.4	Communication topology	Centralized (hub-and-spoke): both nodes communicate exclusively with primary server; no node-to-node direct communication
2.1.5	Communication infrastructure	WiFi 802.11 b/g/n; ESP32 built-in; TCP sockets; RPi4 configured as WiFi AP (SSID: SMG_Primary, 192.168.4.0/24)
2.1.7	Processing topology	Fog: local 9-rule fuzzy EMS on each ESP32; global 27-rule security-aware fuzzy EMS on RPi4; commercial solar adapter handles droop and battery-charging voltage regulation autonomously
2.1.8	Entity hierarchy	IoT Nodes < Users < Administrators
2.2.2	Authentication mechanism	PSK mutual authentication via HKDF-SHA256 (RFC 5869) for IoT nodes; SHA-256-based hash for users/admins
2.2.3	Root of Trust process	4-phase symmetric scheme (Table 2): identity generation (admin workstation) → NVS storage (USB serial) → server DB registration → first-boot authentication
2.2.4	Secure communications	AES-256-GCM with 12-byte random nonces per message; cryptographic hash chain (M_{num} , PRV_{bl}); no TLS certificate management needed on constrained devices
3.1.1	Services defined	4: sensor data ingestion (nodes→server), EMS coordination (server→nodes), authentication API (all entities), monitoring dashboard (server→users)
3.2.1	Access control	RBAC via session token type; API endpoints enforce entity class; nodes POST-only to own data endpoint
3.2.2	Identity storage	ESP32: NVS flash partition (separate from firmware, survives updates, JTAG-disabled for TRL 5+); Server: PostgreSQL-equivalent for SMG + <code>node_registry.json</code> for provisioning records

Table 26: Phase C, Stages 4–5: Implementation technologies and functional elements — SMG application.

Process ID	Parameter	SMG Value
4.1.1	TRL 3 criteria met	Physical nodes operational; mutual authentication functional; PWM energy control active; sensor data logged on primary server; all 8 functional tests passed
4.1.2.1	Node platform	ESP32 + MicroPython 1.22.1 (ESP32-IDF5): built-in WiFi, SHA-256 HW acceleration, NVS; sufficient SRAM (520 KB) for fuzzy EMS + security overhead
4.1.2.2	Cryptography	HKDF-SHA256 (<code>hkdf.py</code> , RFC 5869 compliant); AES-256-GCM (<code>aesgcm</code> custom C module for MicroPython); SHA-256 via ESP32 HW (<code>uhashlib</code>)
4.1.3	Communication protocol	TCP over WiFi 802.11 b/g/n; application-layer PSK protocol (implementation-specific Stage 4 choice; under separate peer review)
4.2.1	Vulnerability mitigations	ESP32 CVE-2021-28135 patched in ESP-IDF5; WiFi credentials moved to NVS; all AES-GCM nonces = <code>os.urandom(12)</code> ; <code>node_key = os.urandom(32)</code> ; JTAG disable deferred to TRL 5+
5.1.1	Primary agent (RPI4)	Python: <code>server.py</code> , <code>auth_service.py</code> (PSK validation + trust score), <code>ems_coordinator.py</code> (27-rule security-aware fuzzy), <code>data_store.py</code> , <code>crypto_utils.py</code>
5.1.2.1	Node power supply	DC-DC buck converter (12V→5V) per node from local battery; isolates ESP32 from shared DC bus; $\approx 90\%$ efficiency vs. $\approx 27\%$ for LDO at 12 V (avoids ≈ 3.8 W peak dissipation)
5.1.2.2	Identity storage	ESP32 NVS: <code>node_id</code> , <code>node_uuid</code> , <code>node_key</code> , <code>node_salt</code> , <code>wifi_ssid</code> , <code>wifi_pass</code> — none present in <code>config.json</code> or firmware binary
5.1.2.3	Node firmware modules	<code>main.py</code> (3 Hz control loop), <code>sensor_module.py</code> (16-sample median ADC), <code>ems_module.py</code> (9-rule fuzzy), <code>security_module.py</code> (P2–P5), <code>metrics.py</code> (CSQ1–CSQ4 collection)
5.2.1	Secure development	NVS for all secrets; <code>os.urandom(12)</code> nonces; no credentials in source

Table 27: Phase D, Stages 6–7: Deployment, operation, and maintenance — SMG application.

Process ID	Parameter	SMG Value
6.1.3	RoT execution	2/2 nodes provisioned (100%): admin generates UUID-4 + 32-byte key per node → writes to ESP32 NVS via USB → registers in server DB → first-boot authentication verified
6.2.1	Functional test coverage	8 tests: boot (FT-01), WiFi from NVS (FT-02), P2 handshake (FT-03), P3 session (FT-04), P4 chain (FT-05), fuzzy EMS (FT-06), ADC saturation (FT-07), degraded mode (FT-08); 100% pass rate
6.2.2	Tamper verification	NVS parameter tampering confirmed as authentication failure (single targeted negative test; full penetration testing deferred to ITER 2)
7.1.1	Monitoring (Stage 7.1.1)	Per-node real-time: V_{bus} , I_{bus} , P_{bus} , V_{gen} , I_{gen} , P_{gen} , D_{pwm} ; authentication status; session history; chain length; heap free
7.1.4	Maintenance cycles	Three maintenance moments during Stages 5–6: (i) HKDF byte slice bug in P3 (M2: code revision); (ii) static nonce in session confirmation, MicroPython default RNG insufficient (M1: technology re-evaluation); (iii) NVS hex encoding error in provisioning (M2: code revision). M3 (architectural redesign) not triggered at TRL 3.
7.2.1	Anomaly detection	Per-node trust score (float 0.0–1.0): initialized 0.80 on P2/P3; –0.30 on P4 failure; –0.40 on V_{bus} anomaly; UNTRUSTED (< 0.30) ⇒ TCP dropped; recovery requires re-auth
7.2.2	Update elements	OTA update requires admin token + firmware signature (deferred to ITER 2)
7.2.3	Incident response	Auth failures logged; > 3 consecutive failures ⇒ quarantine
7.2.4	Security-aware EMS	Global fuzzy EMS (27 rules) on RPi4 accepts the per-node trust score from 7.2.1 as a third input alongside voltage tracking error and bus current, producing security-aware energy management without a separate intrusion response layer

- Kumar, D., Lever, C., Ma, Z., Mason, J., Menscher, D., Seaman, C., Sullivan, N., Thomas, K., Zhou, Y., 2017. Understanding the Mirai botnet, in: Proceedings of the 26th USENIX Security Symposium, USENIX Association, Vancouver, BC, Canada. pp. 1093–1110.
- Ayala, I., Amor, M., Fuentes, L., Troya, J.M., 2015. A software product line process to develop agents for the IoT. *Sensors* 15, 15640–15660.
- Bakiris, E., Oikonomakis, G., 2025. IoT-driven security solutions, in: Cybersecurity: 9th European Interdisciplinary Cybersecurity Conference, EICC 2025, Rennes, France, June 18–19, 2025, Proceedings, Springer Nature. p. 275.
- Blanco, C., Rosado, D.G., Varela-Vaca, Á.J., Gómez-López, M.T., Fernández-Medina, E., 2023. Onto-CARMEN: Ontology-driven approach for Cyber-Physical System security requirements meta-modelling and reasoning. *Internet of Things* 24, 100989.
- Casadei, R., Tsigkanos, C., Viroli, M., Dustdar, S., 2019. Engineering resilient collaborative edge-enabled IoT, in: 2019 IEEE International Conference on Services Computing (SCC), IEEE. pp. 36–45.
- Cicirelli, F., Fortino, G., Guerrieri, A., Spezzano, G., Vinci, A., 2017. Meta-modeling of smart environments: from design to implementation. *Advanced Engineering Informatics* 33, 274–284.
- Cloud Security Alliance, 2023. IoT Security Controls Framework, Version 3. Technical Report. Cloud Security Alliance. URL: <https://cloudsecurityalliance.org/research/working-groups/internet-of-things>.
- Costa, B., Pires, P.F., Delicato, F.C., 2016. Modeling IoT applications with SysML4IoT, in: 2016 42nd Euromicro Conference on Software Engineering and Advanced Applications (SEAA), IEEE. pp. 157–164.
- European Telecommunications Standards Institute, 2020. ETSI EN 303 645 V2.1.1: Cyber security for consumer internet of things: Baseline requirements. European Standard. URL: https://www.etsi.org/deliver/etsi_en/303600_303699/303645/02.01.01_60/en_303645v020101p.pdf.

- European Union Agency for Cybersecurity, 2017. Baseline Security Recommendations for IoT in the Context of Critical Information Infrastructures. Technical Report. European Union Agency for Cybersecurity (ENISA).
- Fagan, M., Marron, J., Brady, K., Cuthill, B., Megas, K., Herold, R., 2021. IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements. NIST Special Publication 800-213. National Institute of Standards and Technology (NIST). Gaithersburg, MD. doi:[10.6028/NIST.SP.800-213](https://doi.org/10.6028/NIST.SP.800-213).
- Fernandez, E.B., Brazhuk, A., 2024. A critical analysis of Zero Trust Architecture (ZTA). *Computer Standards & Interfaces* 89, 103832.
- Fernando, Y., Tseng, M.L., Wahyuni-Td, I.S., de Sousa Jabbour, A.B.L., Chiappetta Jabbour, C.J., Foropon, C., 2023. Cyber supply chain risk management and performance in industry 4.0 era: information system security practices in Malaysia. *Journal of Industrial and Production Engineering* 40, 102–116.
- Fortino, G., Russo, W., Savaglio, C., Shen, W., Zhou, M., 2017. Agent-oriented cooperative smart objects: From IoT system design to implementation. *IEEE Transactions on Systems, Man, and Cybernetics: Systems* 48, 1939–1956.
- Fortino, G., Savaglio, C., Spezzano, G., Zhou, M., 2020. Internet of things as system of systems: A review of methodologies, frameworks, platforms, and tools. *IEEE Transactions on Systems, Man, and Cybernetics: Systems* 51, 223–236.
- Guerrero-Ulloa, G., Rodriguez-Dominguez, C., Hornos, M.J., 2023. Agile methodologies applied to the development of Internet of Things (IoT)-based systems: A review. *Sensors* 23, 790.
- ISO/IEC, 2019. ISO/IEC 9798-3:2019 information technology — security techniques — entity authentication — part 3: Mechanisms using digital signature techniques. International Organization for Standardization. 5th edition.
- Javanmardi, S., Shojafar, M., Mohammadi, R., Alazab, M., Caruso, A.M., 2023. An SDN perspective IoT-fog security: A survey. *Computer Networks* 229, 109732.

- Josyula, S.K., Gupta, D., 2017. A new security methodology for internet of things, in: 2017 International Conference on Computing, Communication and Automation (ICCCA), IEEE. pp. 613–618.
- Licata, J., McWhite, R., Calloway, L., Gilbert, D., Anderson, M., Snyder, J., Miller, J., 2025. Developing Security, Privacy, and Cybersecurity Supply Chain Risk Management Plans for Systems. Technical Report. National Institute of Standards and Technology.
- Makhdoom, I., Abolhasan, M., Lipman, J., Liu, R.P., Ni, W., 2018. Anatomy of threats to the internet of things. *IEEE Communications Surveys & Tutorials* 21, 1636–1675.
- Manate, B., Forti, F., Moore, P., 2014. Applying the Prometheus methodology for an Internet of Things architecture, in: 2014 IEEE/ACM 7th International Conference on Utility and Cloud Computing, IEEE. pp. 435–442.
- Merzouk, S., Cherkaoui, A., Marzak, A., Nawal, S., 2020. IoT methodologies: comparative study. *Procedia Computer Science* 175, 585–590.
- Moreta, N., Aragon, D., Ona, S., Jaramillo, A., Ibarra, J., Jahankhani, H., 2023. Comparison of cybersecurity methodologies for the implementing of a secure IoT architecture, in: *Cybersecurity in the Age of Smart Societies: Proceedings of the 14th International Conference on Global Security, Safety and Sustainability*, London, September 2022, Springer. pp. 9–29.
- Morin, B., Harrand, N., Fleurey, F., 2017. Model-based software engineering to tame the IoT jungle. *IEEE Software* 34, 30–36.
- Muñoz, M., Torres, M., Gil, J.D., Guzmán, J.L., 2025. An Internet of Things platform for heterogeneous data integration: Methodology and application examples. *Journal of Network and Computer Applications* 240, 104197.
- Okika, N., Nwatzie, G.A., Odozor, L., Oni, O., Idoko, I.P., 2025. Addressing IoT-driven cybersecurity risks in critical infrastructure to safeguard public utilities and prevent large-scale service disruptions. *International Journal of Innovative Science and Research Technology* 10.
- Patel, P., Cassou, D., 2015. Enabling high-level application development for the Internet of Things. *Journal of Systems and Software* 103, 62–84.

- Ray, R.K., Chowdhury, F.R., Hasan, M.R., 2024. Blockchain applications in retail cybersecurity: Enhancing supply chain integrity, secure transactions, and data protection. *Journal of Business and Management Studies* 6, 206–214.
- Saqib, M., Moon, A.H., 2023. A systematic security assessment and review of Internet of Things in the context of authentication. *Computers & Security* 125, 103053.
- Sassalou, E.N., Vasileiadis, S., Kazazis, S.A., Protogerou, G., Varvitsiotis, N., Karas, D.S., Giannetsos, T., Tsintzos, S., 2025. A PUF-based root-of-trust for resource-constrained IoT devices, in: 2025 IEEE International Conference on Cyber Security and Resilience (CSR), IEEE. pp. 824–831.
- Savaglio, C., Fortino, G., Gravina, R., Russo, W., 2018. A methodology for integrating internet of things platforms, in: 2018 IEEE International Conference on Cloud Engineering (IC2E), IEEE. pp. 317–322.
- Shahinzadeh, G., Shahinzadeh, H., Tanwar, S., 2024. Security and privacy issues in the Internet of Things: A comprehensive survey of protocols, standards, and the revolutionary role of blockchain, in: 2024 8th International Conference on Smart Cities, Internet of Things and Applications (SCIoT), IEEE. pp. 59–67.
- Shostack, A., 2014. *Threat Modeling: Designing for Security*. Wiley, Indianapolis, IN.
- Sorri, K., Mustafee, N., Seppanen, M., 2022. Revisiting IoT definitions: A framework towards comprehensive use. *Technological Forecasting and Social Change* 179, 121623.
- Spanoudakis, N., Moraitis, P., 2015. Engineering ambient intelligence systems using agent technology. *IEEE Intelligent Systems* 30, 60–67.
- Turner, S.W., Karakus, M., Guler, E., Uludag, S., 2023. A promising integration of SDN and blockchain for IoT networks: A survey. *IEEE Access* .
- UK Government Security, 2024. Secure by design principles. <https://www.security.gov.uk/guidance/secure-by-design/principles/>. Accessed: 30 April 2024.

- Visintin, A., 2024. Secure IoT and the Identity of Things. Ph.D. thesis. Università degli Studi di Padova.
- Yin, R.K., 2014. Case Study Research: Design and Methods. 5th ed., SAGE Publications, Thousand Oaks, CA.
- Zanasi, C., Russo, S., Colajanni, M., 2024. Flexible zero trust architecture for the cybersecurity of industrial IoT infrastructures. *Ad Hoc Networks* , 103414.
- Zhou, I., Makhdoom, I., Shariati, N., Raza, M.A., Keshavarz, R., Lipman, J., Abolhasan, M., Jamalipour, A., 2021. Internet of things 2.0: Concepts, applications, and future directions. *IEEE Access* 9, 70961–71012.